

Scenario 2 - File Management System

Owner: Ananth Chowdary Ramineni
Reviewer: BTH Master's Thesis
Contributors:
Date Generated: Wed Aug 19 2026

Executive Summary

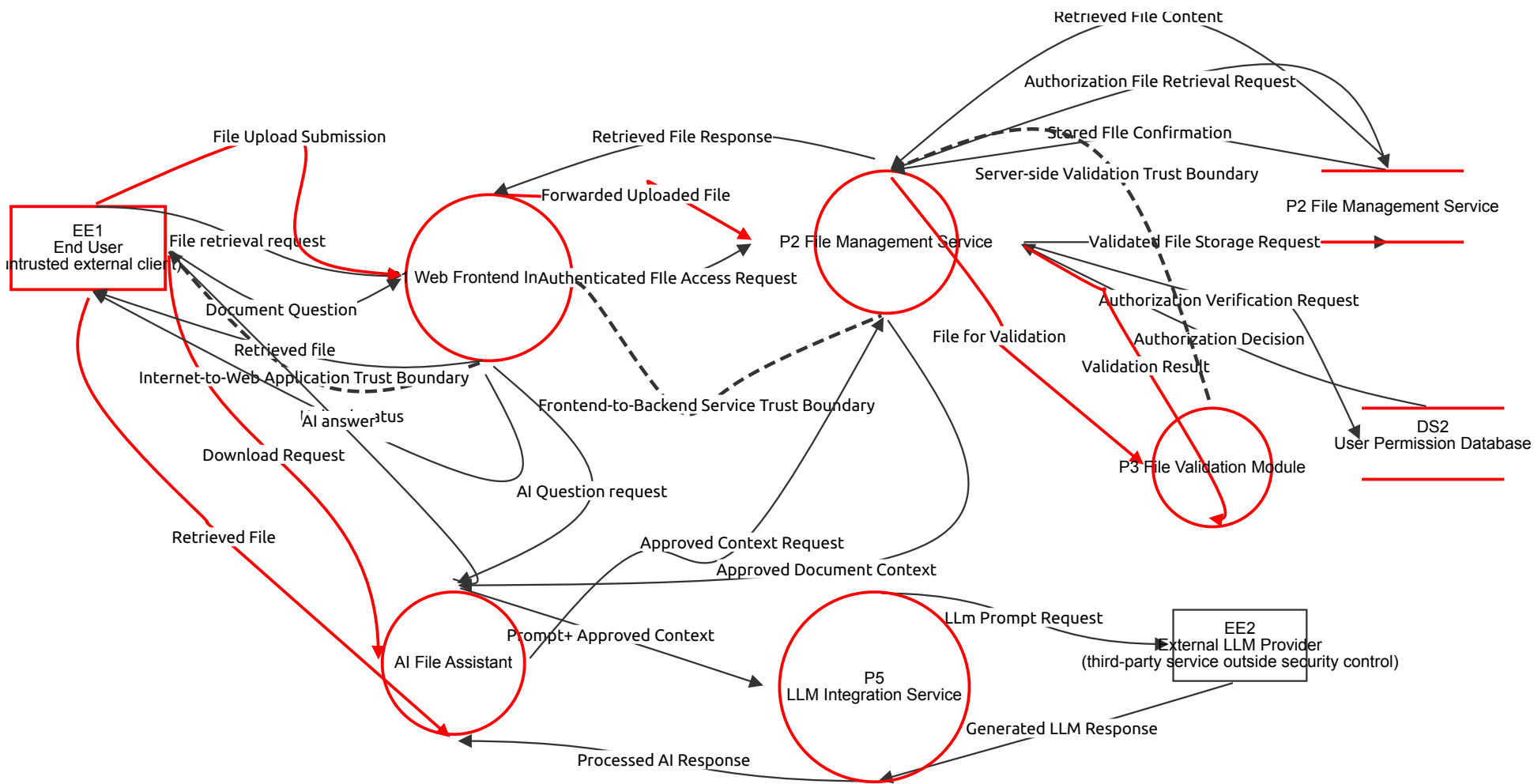
High level system description

Web-based file management system allowing authenticated users to upload, validate, store, and retrieve files through an application server connected to a backend storage database.

Summary

Total Threats	39
Total Mitigated	0
Total Open	39
Open / Critical Severity	0
Open / High Severity	0
Open / Medium Severity	0
Open / Low Severity	0
Open / TBD Severity	39

Scenario 2 – File Management DFD



Scenario 2 – File Management DFD

EE1 End User (untrusted external client) (Actor)

Description: Represents:

- User uploading files
- User requesting files
- User asking questions about documents

Number	Title	Type	Severity	Status	Score	Description	Mitigations
1	CAPTCHA defeat	Elevation of privilege	TBD	Open		See OWASP Automated Threat #9: Automation is used in an attempt to analyse and determination the answers to CAPTCHA tests and related puzzles	Defences include guarding against automation, unguessable CAPTCHA and proper enforcement of behavioral workflow
2	Credential stuffing	Information disclosure	TBD	Open		See OWASP Automated Threat #8: Lists of stolen authentication credentials are tested against the application’s authentication mechanisms to identify whether users have re-used the same login credentials	Defences against Credential Stuffing are described in the OWASP Credential Stuffing Prevention Cheat Sheet, Multi-Factor Authentication being a primary counter-measure

P1 Web Frontend Interface (Process)

Description: Handles:

- File upload interface
- File download interface
- User document questions
- Displaying AI responses

Number	Title	Type	Severity	Status	Score	Description	Mitigations
3	Least privilege	Elevation of privilege	TBD	Open		If a process is comprimised and under control of a malicious actor, horizontal/lateral elevation of privilege can be used to compromise other processes	Processes should run with least privilege that is practical, to minimise the impact of horizontal elevation of privilege
4	Expedition	Tampering	TBD	Open		See OWASP Automated Threat #6: Using speed to violate explicit or implicit assumptions about the application’s normal use to achieve unfair individual gain	Defences include providing enforcement of behavioral workflow and anti-automation
5	Vulnerability scanning	Information disclosure	TBD	Open		See OWASP Automated Threat #14: Systematic enumeration and examination in order to find weaknesses and points where a security vulnerability might exist	Defence includes providing anti-automation
6	Denial of Service	Elevation of privilege	TBD	Open		See OWASP Automated Threat #15: Usage may resemble legitimate application usage but leads to exhaustion of resources	Mitigation or prevention such as providing backoff, resource management and avoiding forced deadlock
7	Footprinting	Information disclosure	TBD	Open		See OWASP Automated Threat #18: Information gathering with the objective of learning as much as possible about the composition, configuration and security mechanisms of the application	Defences include shutting down unnecessary services/ports and excluding information that could identify and compromise security of the organisation

P2 File Management Service (Process)

Description: Controls:

- File access
- Authorization decisions
- File lifecycle
- Storage interaction

It

Number	Title	Type	Severity	Status	Score	Description	Mitigations
8	Least privilege	Elevation of privilege	TBD	Open		If a process is comprimised and under control of a malicious actor, horizontal/lateral elevation of privilege can be used to compromise other processes	Processes should run with least privilege that is practical, to minimise the impact of horizontal elevation of privilege
9	Expedition	Tampering	TBD	Open		See OWASP Automated Threat #6: Using speed to violate explicit or implicit assumptions about the application’s normal use to achieve unfair individual gain	Defences include providing enforcement of behavioral workflow and anti-automation
10	Vulnerability scanning	Information disclosure	TBD	Open		See OWASP Automated Threat #14: Systematic enumeration and examination in order to find weaknesses and points where a security vulnerability might exist	Defence includes providing anti-automation
11	Denial of Service	Elevation of privilege	TBD	Open		See OWASP Automated Threat #15: Usage may resemble legitimate application usage but leads to exhaustion of resources	Mitigation or prevention such as providing backoff, resource management and avoiding forced deadlock
12	Footprinting	Information disclosure	TBD	Open		See OWASP Automated Threat #18: Information gathering with the objective of learning as much as possible about the composition, configuration and security mechanisms of the application	Defences include shutting down unnecessary services/ports and excluding information that could identify and compromise security of the organisation

Download Request (Data Flow)

Description: User requests retrieval of an uploaded file.

Number	Title	Type	Severity	Status	Score	Description	Mitigations
29	Vulnerable transport protocol	Information disclosure	TBD	Open		Older transport protocols are vulnerable and have known vulnerabilities	Use up to date cryptography and transport protocols
30	Fingerprinting	Information disclosure	TBD	Open		See OWASP Automated Threat #4: Specific requests are sent to the application eliciting information in order to profile the application	Defence includes restricting what information is provided, for example version numbers and package details

Retrieved File (Data Flow)

Description: Returns requested file to authenticated user.

Number	Title	Type	Severity	Status	Score	Description	Mitigations
31	Vulnerable transport protocol	Information disclosure	TBD	Open		Older transport protocols are vulnerable and have known vulnerabilities	Use up to date cryptography and transport protocols
32	Fingerprinting	Information disclosure	TBD	Open		See OWASP Automated Threat #4: Specific requests are sent to the application eliciting information in order to profile the application	Defence includes restricting what information is provided, for example version numbers and package details

File retrieval request (Data Flow)

Number	Title	Type	Severity	Status	Score	Description	Mitigations
--------	-------	------	----------	--------	-------	-------------	-------------

File Upload Submission (Data Flow)

Description: Authenticated user uploads a file through the browser.

Number	Title	Type	Severity	Status	Score	Description	Mitigations
26	Vulnerable transport protocol	Information disclosure	TBD	Open		Older transport protocols are vulnerable and have known vulnerabilities	Use up to date cryptography and transport protocols
27	Fingerprinting	Information disclosure	TBD	Open		See OWASP Automated Threat #4: Specific requests are sent to the application eliciting information in order to profile the application	Defence includes restricting what information is provided, for example version numbers and package details

Document Question (Data Flow)

Number	Title	Type	Severity	Status	Score	Description	Mitigations
--------	-------	------	----------	--------	-------	-------------	-------------

Upload status (Data Flow)

Number	Title	Type	Severity	Status	Score	Description	Mitigations
--------	-------	------	----------	--------	-------	-------------	-------------

Retrieved file (Data Flow)

Number	Title	Type	Severity	Status	Score	Description	Mitigations
--------	-------	------	----------	--------	-------	-------------	-------------

Prompt+ Approved Context (Data Flow)

Number	Title	Type	Severity	Status	Score	Description	Mitigations
--------	-------	------	----------	--------	-------	-------------	-------------

LLm Prompt Request (Data Flow)

Number	Title	Type	Severity	Status	Score	Description	Mitigations
--------	-------	------	----------	--------	-------	-------------	-------------

Retrieved File Content (Data Flow)

Number	Title	Type	Severity	Status	Score	Description	Mitigations
--------	-------	------	----------	--------	-------	-------------	-------------

Authenticated File Access Request (Data Flow)

Number	Title	Type	Severity	Status	Score	Description	Mitigations
--------	-------	------	----------	--------	-------	-------------	-------------

Authorization Decision (Data Flow)

Number	Title	Type	Severity	Status	Score	Description	Mitigations
--------	-------	------	----------	--------	-------	-------------	-------------

Stored File Confirmation (Data Flow)

Number	Title	Type	Severity	Status	Score	Description	Mitigations
--------	-------	------	----------	--------	-------	-------------	-------------

Forwarded Uploaded File (Data Flow)

Description: Uploaded file forwarded for backend processing.

Number	Title	Type	Severity	Status	Score	Description	Mitigations
28	Vulnerable transport protocol	Information disclosure	TBD	Open		Older transport protocols are vulnerable and have known vulnerabilities	Use up to date cryptography and transport protocols

Authorization File Retrieval Request (Data Flow)

Number	Title	Type	Severity	Status	Score	Description	Mitigations
--------	-------	------	----------	--------	-------	-------------	-------------

Authorization Verification Request (Data Flow)

Number	Title	Type	Severity	Status	Score	Description	Mitigations
--------	-------	------	----------	--------	-------	-------------	-------------

Validated File Storage Request (Data Flow)

Number	Title	Type	Severity	Status	Score	Description	Mitigations
--------	-------	------	----------	--------	-------	-------------	-------------

Validation Result (Data Flow)

Description: Validation module returns pass or fail.

Number	Title	Type	Severity	Status	Score	Description	Mitigations
36	No Suggestions available		TBD	Open		No suggestions available for this context. Add one manually please	

File for Validation (Data Flow)

Description: Backend sends uploaded file for validation.

Number	Title	Type	Severity	Status	Score	Description	Mitigations
35	No Suggestions available		TBD	Open		No suggestions available for this context. Add one manually please	

Retrieved File Response (Data Flow)

Number	Title	Type	Severity	Status	Score	Description	Mitigations
--------	-------	------	----------	--------	-------	-------------	-------------

AI Question request (Data Flow)

Number	Title	Type	Severity	Status	Score	Description	Mitigations

Approved Context Request (Data Flow)

Number	Title	Type	Severity	Status	Score	Description	Mitigations

Approved Document Context (Data Flow)

Number	Title	Type	Severity	Status	Score	Description	Mitigations

Generated LLM Response (Data Flow)

Number	Title	Type	Severity	Status	Score	Description	Mitigations

Processed AI Response (Data Flow)

Number	Title	Type	Severity	Status	Score	Description	Mitigations

AI answer (Data Flow)

Number	Title	Type	Severity	Status	Score	Description	Mitigations

P3 File Validation Module (Process)

Description: Processes uploaded files: - File type validation - Malware scanning - Metadata validation - Content validation							
Number	Title	Type	Severity	Status	Score	Description	Mitigations
13	Least privilege	Elevation of privilege	TBD	Open		If a process is compromised and under control of a malicious actor, horizontal/lateral elevation of privilege can be used to compromise other processes	Processes should run with least privilege that is practical, to minimise the impact of horizontal elevation of privilege
14	Expedition	Tampering	TBD	Open		See OWASP Automated Threat #6: Using speed to violate explicit or implicit assumptions about the application's normal use to achieve unfair individual gain	Defences include providing enforcement of behavioral workflow and anti-automation
15	Vulnerability scanning	Information disclosure	TBD	Open		See OWASP Automated Threat #14: Systematic enumeration and examination in order to find weaknesses and points where a security vulnerability might exist	Defence includes providing anti-automation
16	Denial of Service	Elevation of privilege	TBD	Open		See OWASP Automated Threat #15: Usage may resemble legitimate application usage but leads to exhaustion of resources	Mitigation or prevention such as providing backoff, resource management and avoiding forced deadlock

AI File Assistant (Process)

Description: Provides: - Document summarization - Document question answering - AI-based assistance							
Number	Title	Type	Severity	Status	Score	Description	Mitigations
17	Least privilege	Elevation of privilege	TBD	Open		If a process is comprimised and under control of a malicious actor, horizontal/lateral elevation of privilege can be used to compromise other processes	Processes should run with least privilege that is practical, to minimise the impact of horizontal elevation of privilege
18	Expedition	Tampering	TBD	Open		See OWASP Automated Threat #6: Using speed to violate explicit or implicit assumptions about the application’s normal use to achieve unfair individual gain	Defences include providing enforcement of behavioral workflow and anti-automation
19	Vulnerability scanning	Information disclosure	TBD	Open		See OWASP Automated Threat #14: Systematic enumeration and examination in order to find weaknesses and points where a security vulnerability might exist	Defence includes providing anti-automation
20	Denial of Service	Elevation of privilege	TBD	Open		See OWASP Automated Threat #15: Usage may resemble legitimate application usage but leads to exhaustion of resources	Mitigation or prevention such as providing backoff, resource management and avoiding forced deadlock
21	Footprinting	Information disclosure	TBD	Open		See OWASP Automated Threat #18: Information gathering with the objective of learning as much as possible about the composition, configuration and security mechanisms of the application	Defences include shutting down unnecessary services/ports and excluding information that could identify and compromise security of the organisation

EE2 External LLM Provider (third-party service outside security control) (Actor)

Description: Represents: - OpenAI API - Azure OpenAI - Other third-party LLM							
Number	Title	Type	Severity	Status	Score	Description	Mitigations

P5 LLM Integration Service (Process)

Description: Manages: - Prompt construction - Context filtering - Communication with external LLM Security purpose: Prevents: - Sending sensitive data - Sending unauthorized documents - Direct AI access							
Number	Title	Type	Severity	Status	Score	Description	Mitigations
37	Expedition	Tampering	TBD	Open		See OWASP Automated Threat #6: Using speed to violate explicit or implicit assumptions about the application’s normal use to achieve unfair individual gain	Defences include providing enforcement of behavioral workflow and anti-automation
38	Vulnerability scanning	Information disclosure	TBD	Open		See OWASP Automated Threat #14: Systematic enumeration and examination in order to find weaknesses and points where a security vulnerability might exist	Defence includes providing anti-automation
39	Denial of Service	Elevation of privilege	TBD	Open		See OWASP Automated Threat #15: Usage may resemble legitimate application usage but leads to exhaustion of resources	Mitigation or prevention such as providing backoff, resource management and avoiding forced deadlock

DS2 User Permission Database (Store)

Description: Stores:

- User ID
- File ownership
- Roles
- Access control rules

Number	Title	Type	Severity	Status	Score	Description	Mitigations
40	Scraping	Information disclosure	TBD	Open		See OWASP Automated Threat #11: Collecting accessible data and/or processed output from the application	Detect fake or compromised accounts, ensure information is accessible only with authentication and authorisation
41	Skewing	Elevation of privilege	TBD	Open		See OWASP Automated Threat #16: Automated repeated clicking or requesting or submitting content, affecting application based metrics such as counts, and measures of frequency and/or rate	Defences include control of interaction frequency or proper enforcement of a single unique action
42	Spamming	Elevation of privilege	TBD	Open		See OWASP Automated Threat #17: Storing malicious such as malware, Iframe distribution, photographs & videos, advertisements, referrer spam and tracking/surveillance code	Defences include detecting embedded malicious code, controlling interaction frequency and enforcement of a single unique action

P2 File Management Service (Store)

Description: Stores:

- Documents
- File content
- File metadata

Number	Title	Type	Severity	Status	Score	Description	Mitigations
43	Scraping	Information disclosure	TBD	Open		See OWASP Automated Threat #11: Collecting accessible data and/or processed output from the application	Detect fake or compromised accounts, ensure information is accessible only with authentication and authorisation
44	Skewing	Elevation of privilege	TBD	Open		See OWASP Automated Threat #16: Automated repeated clicking or requesting or submitting content, affecting application based metrics such as counts, and measures of frequency and/or rate	Defences include control of interaction frequency or proper enforcement of a single unique action
45	Spamming	Elevation of privilege	TBD	Open		See OWASP Automated Threat #17: Storing malicious such as malware, Iframe distribution, photographs & videos, advertisements, referrer spam and tracking/surveillance code	Defences include detecting embedded malicious code, controlling interaction frequency and enforcement of a single unique action